

Phase D - S3 Risk Assessment & Threat Model

Objective: Build a threat model showing how an attacker could exploit exposed Amazon S3 data and recommend appropriate mitigations.

Risk Assessment Matrix

Asset	Threat	Likelihood	Impact	Risk	Recommended Mitigation
S3 Data Bucket	Public exposure caused by a permissive bucket policy or wildcard principal.	High	High	High	Enable S3 Block Public Access and remove unnecessary public or wildcard principals.
S3 Bucket Objects	Unauthorized access caused by excessive IAM permissions such as broad S3 actions.	Medium	High	High	Apply least privilege, restrict S3 actions/resources, and periodically review IAM permissions.
CloudTrail Logs Bucket	Unauthorized modification or deletion of audit logs, reducing investigation capability.	Medium	High	High	Restrict write/delete access, enable versioning where appropriate, and protect audit logging.
S3 Bucket ACLs	Public access through AllUsers or AuthenticatedUsers ACL grants.	Medium	High	High	Enable Block Public ACLs and use Bucket Owner Enforced Object Ownership.
Sensitive Data	Data theft or disclosure following accidental public exposure.	Medium	High	High	Block public access, encrypt data, monitor access, and use least-privilege IAM.
S3 Configuration	Security misconfiguration remains undetected and creates prolonged exposure.	Medium	Medium	Medium	Use AWS Config, CloudTrail, IAM Access Analyzer/Security Hub, and periodic configuration reviews.

Threat Scenario

An attacker discovers an exposed S3 bucket through enumeration or information disclosed by an application. If the bucket uses a permissive policy such as a wildcard Principal or an insecure public ACL, the attacker may be able to access objects without authorization. Sensitive information could then be downloaded or exposed. If excessive write or delete permissions are also present, data integrity and availability could be affected.

Potential Impact

Potential consequences include loss of confidentiality, unauthorized data modification, data deletion, loss of availability, weakened auditability, regulatory or compliance issues, and reputational damage.

Recommended Controls

Enable S3 Block Public Access; remove unnecessary public ACLs and wildcard principals; implement least-privilege IAM roles and policies; encrypt sensitive data; enable appropriate versioning and logging; protect CloudTrail logs; and continuously review S3 permissions and configuration using AWS security and monitoring services.

Risk Rating Method

Likelihood and impact are assessed qualitatively as Low, Medium, or High. Overall risk reflects the combined probability of exploitation and the potential business/security impact.